
UNIVERSIDADE FEDERAL DE ALFENAS – UNIFAL-MG

COMPUTER SCIENCE

STPA Analysis

Control Action: *Set Milestone* (Developer)

UCAs, Loss Scenarios, and Derived Requirements

Student 1: Jeann Victor Batista (*RA: 2024.1.08.014*)

Student 2: Pedro Augusto de Souza Finnochio (*RA: 2024.1.08.020*)

Student 3: Thiago Martins da Silva (*RA: 2024.1.08.023*)

Academic report submitted as part of the delivery requirements
for **Tasks 6, 7, and 8** in the course

*Computational Models and Techniques for Safety and
Security Requirements Analysis*

Professor: Rodrigo Martins Pagliares

Contents

1	Introduction	2
2	Unsafe Control Actions (UCAs)	2
3	Process Model Variables (PMVs)	4
4	Controller Level Constraints	4
5	Loss Scenarios	6
6	Derived Requirements	14

1. Introduction

This report presents the application of *System-Theoretic Process Analysis* (STPA) to a DevSecOps automation pipeline for the healthcare system *SisAPEC*, deployed across primary health care units within the Brazilian Unified Health System (SUS). The analysis is grounded in the requirements of the Brazilian General Data Protection Law (LGPD), using STPA to identify how inadequate controls and unsafe socio-technical interactions throughout the software lifecycle may compromise patient data privacy, system security, and service availability.

The work focuses on the control action **Set Milestone**, executed by the **Developer** role within the refined DevSecOps control structure (Figure 3 of the project specification). This control action was selected from the provided list of control actions and subjected to a full STPA analysis spanning Steps 3 and 4 of the methodology.

The document is organized as follows. **Task 6** (Section 2, Section 3, and Section 4) covers STPA Step 3: it identifies the **Unsafe Control Actions (UCAs)** across the four standard categories, derives the corresponding **Process Model Variables (PMVs)** that the Developer must accurately maintain to issue the control action safely, and establishes the **Controller Level Constraints** that the Developer must satisfy to prevent the identified UCAs. **Task 7** (Section 5) covers STPA Step 4: it presents **Loss Scenarios** that, without involving component failures, lead the Developer to issue the previously identified UCAs. **Task 8** (Section 6) concludes the analysis with **Derived Requirements** aimed at mitigating or eliminating the identified loss scenarios.

2. Unsafe Control Actions (UCAs)

Unsafe Control Actions (UCAs) determine under which conditions the provision or omission of a control action results in a system-level hazardous state. Following the STPA methodological structure rigorously, Table 1 organizes the Developer's UCAs for the *Set Milestone* command across the four standard categories.

Two additional UCAs (**UCA-10.5** and **UCA-10.6**) refine the analysis by incorporating realistic DevSecOps pipeline dynamics: dependency on the pipeline verification status and the completeness level of issue descriptions, respectively.

Table 1: Unsafe Control Actions for *Set Milestone* (Developer)

Category	Unsafe Control Action (UCA)	Hazards
Not Providing Causes Hazard	UCA-10.1: Developer DOES NOT PROVIDE <i>Set Milestone</i> when an issue involves privacy, security, or system availability.	[H-2, H-3, H-4, H-5]
Providing Causes Hazard	UCA-10.2: Developer PROVIDES <i>Set Milestone</i> with an incorrect date or wrong project phase for an issue that involves privacy, security, or system availability.	[H-2, H-3, H-5]
	UCA-10.5: Developer PROVIDES <i>Set Milestone</i> to an issue involving privacy or security without verifying whether the milestone phase is consistent with the current pipeline verification status.	[H-2, H-4]
Too Early, Too Late, Out of Order	UCA-10.3: Developer PROVIDES <i>Set Milestone</i> AFTER the start of development of the issue, when it involves privacy, security, or system availability.	[H-2, H-3, H-4, H-5]
	UCA-10.6: Developer PROVIDES <i>Set Milestone</i> to a privacy or security issue before it has been properly described or labeled, making it impossible to assess its actual urgency or scope.	[H-3, H-4, H-5]
Stopped Too Soon / Applied Too Long	UCA-10.4: Developer REMOVES the milestone from an issue involving privacy, security, or system availability before its completion.	[H-2, H-3, H-4, H-5]

3. Process Model Variables (PMVs)

Process Model Variables represent the states and information that the controller (in this case, the Developer) must accurately know in order to make safe decisions and issue the control action correctly.

Table 2 describes the variables required for the safe execution of *Set Milestone*, their value domains, and traceability links to the identified UCAs.

Table 2: Process Model Variables for *Set Milestone* (Developer)

ID	Variable	Possible Values	Related UCA(s)
PMV-1	Issue type	Security / Privacy / Availability / Feature / Bug	UCA-10.1, 10.5, 10.6
PMV-2	Issue development status	Not started / In progress / Completed / Blocked	UCA-10.3, 10.4
PMV-3	Current project phase / milestone	Planning / Development / Testing / Release	UCA-10.2, 10.3
PMV-4	Issue description completeness	Complete / Incomplete / Missing	UCA-10.6
PMV-5	Pipeline verification status	Passing / Failing / Not yet executed	UCA-10.5
PMV-6	Milestone deadline validity	Valid / Expired / Not defined	UCA-10.1, 10.2, 10.4

4. Controller Level Constraints

Controller Level Constraints (CLCs) specify the behaviors that the Developer, as the controller responsible for issuing *Set Milestone*, must satisfy in order to prevent

the Unsafe Control Actions identified in Section 2 from occurring. Each constraint is expressed as a mandatory or prohibited behavior and is directly traceable to the UCA that motivated it.

Table 3 presents all Controller Level Constraints derived from UCA-10.1 through UCA-10.6.

Table 3: Controller Level Constraints for *Set Milestone* (Developer)

ID	Controller Level Constraint	Related UCA
CLC-10.1	Developer MUST PROVIDE <i>Set Milestone</i> when a privacy, security, or system availability issue is created, and MUST do so before development activities begin.	UCA-10.1
CLC-10.2	Developer MUST NOT PROVIDE <i>Set Milestone</i> with an incorrect date or a project phase that does not correspond to the actual stage of the issue.	UCA-10.2
CLC-10.3	Developer MUST NOT PROVIDE <i>Set Milestone</i> after development activities on a privacy, security, or system availability issue have already started.	UCA-10.3
CLC-10.4	Developer MUST NOT REMOVE <i>Set Milestone</i> from a privacy, security, or system availability issue before all required development, testing, and verification activities have been completed.	UCA-10.4
CLC-10.5	Developer MUST NOT PROVIDE <i>Set Milestone</i> without first verifying that the milestone phase is consistent with the current pipeline verification status.	UCA-10.5
CLC-10.6	Developer MUST NOT PROVIDE <i>Set Milestone</i> before the issue has been properly described and labeled, with all mandatory classification fields completed.	UCA-10.6

5. Loss Scenarios

Loss Scenarios describe the causal chains of events and conditions that lead the Developer to issue an Unsafe Control Action (UCA), without including component failures as a causal factor. Following STPA Step 4, as formalized by John Thomas, each scenario presented in this section traces how flawed process models, inadequate feedback, or organizational pressures may cause the Developer to issue the *Set Milestone* control action incorrectly, too early, too late, or to remove it prematurely.

Tables 4 and 5 present two Loss Scenarios derived from UCA-10.1 and UCA-10.3, respectively. In both scenarios, all involved components behave according to their specifications, and no component failure occurs as a causal factor. Tables 6 and 7 present two additional Loss Scenarios derived from UCA-10.4 and UCA-10.6, respectively.

Table 4: Loss Scenario for UCA-10.1 (No Component Failure)

Field	Content
Related UCA	UCA-10.1: Developer DOES NOT PROVIDE <i>Set Milestone</i> when a privacy or security issue is created and before development begins.
Controllers Involved	Developer, Issue Tracking System, Project Management Platform
Scenario Archetype	Class 1 – Unsafe Controller Behavior
High-Level Scenario	A required milestone was not created for a privacy or security issue, resulting in inadequate planning, monitoring, and prioritization of security-related activities.
High-Level Solution	The development process must require milestone assignment before development activities associated with privacy or security issues can begin.

Continued on next page...

Field	Content
Refined Scenario	A privacy-related issue involving the processing of sensitive patient information is identified during the maintenance of SisAPEC. The issue is correctly registered in the Issue Tracking System and assigned to a developer. Due to schedule pressure and the perception that the correction is relatively minor, the developer begins implementing the fix immediately without creating the required milestone. The developer's flawed mental model regarding PMV-1 (Issue Type) leads to an underestimation of the issue's classification as a privacy-related task requiring formal tracking. Because no milestone exists, project dashboards and management reports do not identify the activity as a tracked security-related task. As development progresses, the issue receives less visibility than other planned activities. The absence of milestone tracking delays coordination, monitoring, and verification activities, increasing the likelihood that the vulnerability remains active in production longer than intended, potentially contributing to privacy and security violations involving sensitive healthcare data. All involved components behaved according to specification and no component failure occurred.
Causal Factors	Flawed Mental Model regarding PMV-1 (Issue Type), Inadequate Process Enforcement, Missing Management Visibility, Inadequate Oversight
Refined Solution	The Issue Tracking System shall require milestone assignment before work can begin on any issue classified as privacy-related or security-related.

Table 5: Loss Scenario for UCA-10.3 (No Component Failure)

Field	Content
Related UCA	UCA-10.3: Developer PROVIDES <i>Set Milestone</i> AFTER the start of development of the issue, when it involves privacy, security, or system availability.
Controllers Involved	Developer, Issue Tracking System, Project Manager
Scenario Archetype	Class 1 – Unsafe Controller Behavior
High-Level Scenario	The milestone is assigned only after development activities have already started, reducing planning effectiveness and limiting visibility of security-critical work.
High-Level Solution	Milestones must be assigned before development activities begin on any privacy, security, or system availability issue.

Continued on next page...

Field	Content
Refined Scenario	A security vulnerability affecting access control mechanisms is identified in SisAPEC. The developer receives the task and immediately starts implementing corrective changes because the issue is considered urgent. However, the milestone is not assigned during task creation. The developer's flawed process model regarding PMV-2 (Issue Development Status) and PMV-3 (Current Project Phase) causes the developer to treat milestone assignment as a non-critical administrative step that can be deferred. Several days later, after substantial development work has already occurred, the developer realizes that the issue should have been associated with a milestone and creates one retroactively. During the period without milestone tracking, project management dashboards fail to properly represent the activity, management receives incomplete progress information, and security-related deadlines are not adequately monitored. As a result, coordination activities are weakened and the organization loses visibility over a critical security remediation effort.
Causal Factors	Delayed Feedback, Flawed Process Model regarding PMV-2 (Issue Development Status) and PMV-3 (Current Project Phase), Inadequate Project Monitoring, Human Error
Refined Solution	The DevSecOps workflow shall prevent developers from transitioning a privacy or security issue into the development state until a milestone has been assigned and validated by the Issue Tracking System.

Table 6: Loss Scenario for UCA-10.4 (No Component Failure)

Field	Content
Related UCA	UCA-10.4: Developer REMOVES the milestone from an issue involving privacy, security, or system availability before its completion.
Controllers Involved	Developer, Project Manager, Issue Tracking System
Scenario Archetype	Class 1 – Unsafe Controller Behavior
High-Level Scenario	A milestone is removed from a security or privacy issue before all required activities are completed, causing loss of tracking and management visibility over critical work.
High-Level Solution	Milestones shall remain associated with security and privacy issues until all development, testing, and verification activities have been completed and formally verified.

Continued on next page...

Field	Content
Refined Scenario	A milestone associated with a security correction in SisAPEC is nearing its planned completion date. The primary development activities have been completed, and the developer believes the issue has been fully resolved. To reflect perceived progress and maintain favorable project schedule metrics, the developer removes the milestone from the issue before final security validation and verification activities are performed. The developer's flawed process model regarding PMV-2 (Issue Development Status) leads to an incorrect assessment that the issue status is "Completed" when it should remain "In Progress" pending verification. Subsequent testing reveals unresolved weaknesses in the implemented solution. Because the milestone has already been removed, management assumes the work is complete and initiates no additional monitoring. As a result, security deficiencies remain undetected for an extended period, increasing the likelihood of future privacy or security incidents involving healthcare data. All involved components behaved according to specification and no component failure occurred.
Causal Factors	Inadequate Verification, Human Error, Flawed Process Model regarding PMV-2 (Issue Development Status), Missing Feedback
Refined Solution	The project management system shall prevent milestone removal from privacy or security issues until all required validation and verification activities have been formally completed and recorded in the Issue Tracking System.

Table 7: Loss Scenario for UCA-10.6 (No Component Failure)

Field	Content
Related UCA	UCA-10.6: Developer PROVIDES <i>Set Milestone</i> to a privacy or security issue before it has been properly described or labeled, making it impossible to assess its actual urgency or scope.
Controllers Involved	Developer, Issue Tracking System, Project Manager
Scenario Archetype	Class 1 – Unsafe Controller Behavior
High-Level Scenario	A milestone is created before sufficient information about the issue is available, resulting in inaccurate planning and unreliable project tracking.
High-Level Solution	Milestones shall only be created after the issue definition and classification activities have been completed, ensuring that all mandatory fields are present and accurate.

Continued on next page...

Field	Content
Refined Scenario	A privacy-related issue is initially reported in SisAPEC. The developer immediately creates a milestone to accelerate project planning without waiting for the issue analysis to be completed. At that moment, important details regarding the scope, impact, classification, and required corrective actions of the issue have not yet been fully determined. The developer's flawed mental model regarding PMV-4 (Issue Description Completeness) leads to the incorrect belief that the available information is sufficient to support milestone creation. During subsequent team discussions, the issue requirements change significantly and additional security controls are identified as necessary. Because the milestone was established using incomplete information, project planning becomes inconsistent with the actual work required. Management decisions and progress monitoring rely on inaccurate milestone data, increasing the likelihood of schedule delays and inadequate prioritization of security activities. All involved components behaved according to specification and no component failure occurred. The unsafe outcome arises solely from a decision made under conditions of incomplete information.
Causal Factors	Incomplete Information, Premature Decision Making, Flawed Mental Model regarding PMV-4 (Issue Description Completeness), Inadequate Coordination
Refined Solution	The Issue Tracking System shall enforce that all mandatory issue-definition and classification fields have been completed and reviewed before allowing the creation of an associated milestone.

6. Derived Requirements

Derived Requirements specify concrete, implementable, and testable behaviors that the DevSecOps pipeline and its supporting tools must enforce in order to mitigate or eliminate the Loss Scenarios identified in Section 5.

Table 8 presents the requirements derived from all four Loss Scenarios associated with UCA-10.1, UCA-10.3, UCA-10.4, and UCA-10.6.

Table 8: Derived Requirements for *Set Milestone* (Developer)

ID	Derived Requirement
DR-1	The Issue Tracking System shall block the transition of any privacy, security, or system availability issue into the development state unless a valid milestone has been assigned to that issue.
DR-2	The DevSecOps CI/CD pipeline shall automatically verify the existence of an assigned and valid milestone before allowing merge requests or pipeline executions associated with privacy or security issues to proceed.
DR-3	The Issue Tracking System shall enforce that all mandatory issue-definition and classification fields have been completed before allowing the creation of an associated milestone.
DR-4	The project management system shall prevent the removal of a milestone from any privacy, security, or system availability issue unless all required validation and verification activities for that issue have been formally recorded as completed in the Issue Tracking System.